CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: BlackEnergy (CyberDefenders)

Análisis forense de memoria en Windows mediante Volatility para identificar procesos maliciosos, detectar inyección de código y analizar artefactos asociados a una infección de malware BlackEnergy.

Sebastian David
Torres Reyes

Escenario:

Una corporación multinacional ha sufrido un ciberataque que resultó en el robo de datos confidenciales. El ataque empleó una variante del malware BlackEnergy v2. El equipo de seguridad de la empresa ha realizado una adquisición de memoria de la máquina infectada y solicita su experiencia como analista SOC para analizar dicha adquisición y comprender el alcance y el impacto del ataque.

Herramientas utilizadas:

- Volatility 2

Resumen:

El incidente analizado describe el compromiso de un sistema Windows mediante una variante del malware BlackEnergy. El análisis de la memoria evidenció la ejecución de un proceso sospechoso denominado rootkit.exe, lo que sugiere actividad maliciosa en el sistema. Asimismo, se identificaron indicios de evasión mediante el uso de procesos legítimos, observándose la posible inyección de la biblioteca msxml3r.dll en el proceso svchost.exe, lo que permitiría al malware operar con mayores privilegios y dificultar su detección. Adicionalmente, se detectó el archivo str.sys, asociado a un controlador de tipo SERVICE_KERNEL_DRIVER, lo que sugiere mecanismos de persistencia a nivel kernel. Durante el análisis también se observó la ejecución de procesos como cmd.exe, lo que podría estar relacionado con actividades de control o ejecución de comandos en el sistema comprometido. Se identificó tráfico mediante el servicio HTTP hacia la dirección IP 86.51.94.107, potencialmente asociado a infraestructura de comando y control (C2). Finalmente, de acuerdo con fuentes de inteligencia de amenazas, el malware BlackEnergy ha sido previamente vinculado al grupo APT conocido como “Sandworm”, asociado a operaciones atribuidas a la GRU de Rusia; no obstante, dicha atribución no puede confirmarse exclusivamente con la evidencia obtenida en este análisis.

P1: ¿Qué perfil de volatilidad sería el más adecuado para esta máquina?

R: WinXPSP2x86

Mediante la herramienta Volatility 2 se identificaron los perfiles de sistema compatibles con la imagen de memoria mediante el plugin imageinfo. La herramienta mostró la información del perfil mas adecuado para la máquina, WinXPSP2x86.

```
Volatility Foundation Volatility Framework 2.6
INFO    : volatility.debug    : Determining profile based on KDBG search...
          Suggested Profile(s) : WinXPSP2x86, WinXPSP3x86 (Instantiated with WinXPSP2x86)
                     AS Layer1 : IA32PagedMemory (Kernel AS)
                     AS Layer2 : FileAddressSpace (E:\CTFs\CyberDefenders\Medium\BlackEnergy\CYBERDEF-567078-20230213-17
1333.raw)
                      PAE type : No PAE
                           DTB : 0x39000L
                          KDBG : 0x8054cde0L
          Number of Processors : 1
     Image Type (Service Pack) : 3
                KPCR for CPU 0 : 0xffdff000L
             KUSER_SHARED_DATA : 0xffdf0000L
           Image date and time : 2023-02-13 18:29:11 UTC+0000
     Image local date and time : 2023-02-13 10:29:11 -0800
```

P2: ¿Cuántos procesos estaban en ejecución cuando se adquirió la imagen?

R: 19

Para visualizar la lista de procesos se usó el plugin pslist y se exportó la salida en un archivo CSV.

```
78-20230213-171333.raw --profile=WinXPSP2x86 pslist
Volatility Foundation Volatility Framework 2.6
Offset(V)  Name                    PID   PPID   Thds     Hnds   Sess  Wow64 Start                          Exit
---------- -------------------- ------ ------ ------ -------- ------ ------ ------------------------------ ------------
----------------
0x89c037f8 System                    4      0     55      245 ------      0

0x89965020 smss.exe                368      4      3       19 ------      0 2023-02-14 04:54:15 UTC+0000

0x89a98da0 csrss.exe               592    368     11      321      0      0 2023-02-14 04:54:15 UTC+0000

0x89a88da0 winlogon.exe            616    368     18      508      0      0 2023-02-14 04:54:15 UTC+0000

0x89938998 services.exe            660    616     15      240      0      0 2023-02-14 04:54:15 UTC+0000

0x89aa0020 lsass.exe               672    616     21      335      0      0 2023-02-14 04:54:15 UTC+0000

0x89aaa3d8 VBoxService.exe         832    660      9      115      0      0 2023-02-14 04:54:15 UTC+0000

0x89aab590 svchost.exe             880    660     21      295      0      0 2023-02-13 17:54:16 UTC+0000

0x89a9f6f8 svchost.exe             968    660     10      244      0      0 2023-02-13 17:54:17 UTC+0000

0x89730da0 svchost.exe            1060    660     51     1072      0      0 2023-02-13 17:54:17 UTC+0000

0x897289a8 svchost.exe            1108    660      5       78      0      0 2023-02-13 17:54:17 UTC+0000

0x899adda0 svchost.exe            1156    660     13      192      0      0 2023-02-13 17:54:17 UTC+0000
```

En total se identificaron 19 procesos activos en el momento de la adquisición de la memoria.

	A	B
1	Offset(V)	Name
2	0x89c037f8	System
3	0x89965020	smss.exe
4	0x89a98da0	csrss.exe
5	0x89a88da0	winlogon.exe
6	0x89938998	services.exe
7	0x89aa0020	lsass.exe
8	0x89aaa3d8	VBoxService.e
9	0x89aab590	svchost.exe
14	0x89733938	explorer.exe
15	0x897075d0	spoolsv.exe
16	0x89694388	wscntfy.exe
17	0x8969d2a0	alg.exe
18	0x89982da0	VBoxTray.exe
19	0x8994a020	msmsgs.exe
20	0x89a0b2f0	taskmgr.exe
21	0x899dd740	rootkit.exe
22	0x89a18da0	cmd.exe
23	0x896c5020	notepad.exe
26	0x89a0fda0	DumpIt.exe
27	Total	19

P3: ¿Cuál es el ID del proceso cmd.exe?

R: 1960

Mediante el plugin pslist se identificó el proceso cmd.exe con PID 1960, lo que indica que una instancia de la consola de comandos estaba activa en el sistema comprometido.

	A	B	C
1	Offset(V)	Name	PID
22	0x89a18da0	cmd.exe	1960

P4: ¿Cuál es el nombre del proceso más sospechoso?

R: rootkit.exe

Se encontró el proceso rootkit.exe con PID 964. Un rootkit es un tipo de malware diseñado para obtener acceso de administrador a un ordenador o red, una de las características de este malware es la presencia oculta para el usuario y las herramientas de seguridad. Cabe destacar que los atacantes normalmente utilizan nombres similares a procesos legítimos de Windows para evitar ser detectados.

	Offset(V)	Name	PID	PPID
21	0x899dd740	rootkit.exe	964	1484

P5: ¿Qué proceso presenta la mayor probabilidad de inyección de código?

R: svchost.exe

El proceso svchost.exe es uno de los objetivos mas comunes por los atacantes por su diseño y función. Debido a que svchost.exe es un proceso legítimo del sistema que ejecuta múltiples servicios de Windows, suele ser utilizado por malware para ocultar actividad maliciosa o realizar inyección de código.

	Offset(V)	Name	PID	PPID
9	0x89aab590	svchost.exe	880	660
10	0x89a9f6f8	svchost.exe	968	660
11	0x89730da0	svchost.exe	1060	660
12	0x897289a8	svchost.exe	1108	660
13	0x899adda0	svchost.exe	1156	660

P6: En el proceso reciente se menciona un archivo extraño. Proporcione la ruta completa de dicho archivo.

R: C:\WINDOWS\system32\drivers\str.sys

Tras analizar las handles de tipo archivo que tiene el proceso svchost.exe de PID 880 mediante el plugin handles, se visualizó un archivo extraño str.sys ubicado en \Device\HarddiskVolume1\WINDOWS\system32\drivers\str.sys.

```
78-20230213-171333.raw --profile=WinXPSP2x86 handles -p880 -t file
Volatility Foundation Volatility Framework 2.6
Offset(V)     Pid     Handle     Access Type             Details
---------- ------ ---------- ---------- ---------------- -------
0x89a28890    880        0xc   0x100020 File             \Device\HarddiskVolume1\WINDOWS\system32
0x89a1a6f8    880       0x50   0x100001 File             \Device\KsecDD
0x89937358    880       0x68   0x100020 File             \Device\HarddiskVolume1\WINDOWS\WinSxS\x86_Microsoft.Windows.Co
mmon-Controls_6595b64144ccf1df_6.0.2600.5512_x-ww_35d4ce83
0x899d0250    880       0xbc   0x12019f File             \Device\NamedPipe\net\NtControlPipe2
0x89a17a50    880      0x100   0x100000 File             \Device\Dfs
0x89732cb8    880      0x158   0x12019f File             \Device\NamedPipe\lsarpc
0x8969fee0    880      0x274   0x12019f File             \Device\Termdd
0x89ab3478    880      0x294   0x12019f File             \Device\Termdd
0x89ab3978    880      0x29c   0x12019f File             \Device\Termdd
0x896bcd18    880      0x2b8   0x12019f File             \Device\NamedPipe\Ctx_WinStation_API_service
0x8997a248    880      0x2bc   0x12019f File             \Device\NamedPipe\Ctx_WinStation_API_service
0x899a24b0    880      0x304   0x12019f File             \Device\Termdd
0x89a00f90    880      0x33c   0x12019f File             \Device\{9DD6AFA1-8646-4720-836B-EDCB1085864A}
0x89af0cf0    880      0x340   0x12019f File             \Device\HarddiskVolume1\WINDOWS\system32\drivers\str.sys
0x89993f90    880      0x3d8   0x100020 File             \Device\HarddiskVolume1\WINDOWS\WinSxS\x86_Microsoft.Windows.Co
mmon-Controls_6595b64144ccf1df_6.0.2600.5512_x-ww_35d4ce83
0x89958b78    880      0x3e4   0x12019f File             \Device\HarddiskVolume1\WINDOWS\system32\config\systemprofile\L
ocal Settings\Temporary Internet Files\Content.IE5\index.dat
0x899fe2e0    880      0x3f8   0x12019f File             \Device\HarddiskVolume1\WINDOWS\system32\config\systemprofile\C
ookies\index.dat
0x89a492e8    880      0x400   0x12019f File             \Device\HarddiskVolume1\WINDOWS\system32\config\systemprofile\L
ocal Settings\History\History.IE5\index.dat
0x8968111d8    880      0x424   0x100020 File             \Device\HarddiskVolume1\WINDOWS\WinSxS\x86_Microsoft.Windows.Co
```

P7: ¿Cuál es el nombre del archivo DLL inyectado que se cargó desde el proceso reciente?

R: msxml3r.dll

El plugin ldrmodules es útil para verificar bibliotecas que están intentando ocultarse del análisis convencional ya que registra detalles de las bibliotecas legítimas como el orden en que se cargaron, su ubicación en la memoria y el orden en que se inicializaron (InLoadOrder, InMemoryOrder y InInitializationOrder). Se pudo notar que la biblioteca msxml3r.dll es la única biblioteca que tiene indicios de no ser legítima al no estar vinculado a ninguna de las 3 listas de módulos. Se determinó que la biblioteca msxml3r.dll es el archivo DLL inyectado.

```
64144ccf1df_6.0.2600.5512_x-ww_35d4ce83\comctl32.dll
     880 svchost.exe          0x71a50000 True   True   True  \WINDOWS\system32\mswsock.dll
     880 svchost.exe          0x5b860000 True   True   True  \WINDOWS\system32\netapi32.dll
     880 svchost.exe          0x00670000 True   True   True  \WINDOWS\system32\xpsp2res.dll
     880 svchost.exe          0x76e90000 True   True   True  \WINDOWS\system32\rasman.dll
     880 svchost.exe          0x77a80000 True   True   True  \WINDOWS\system32\crypt32.dll
     880 svchost.exe          0x71ab0000 True   True   True  \WINDOWS\system32\ws2_32.dll
     880 svchost.exe          0x77cc0000 True   True   True  \WINDOWS\system32\activeds.dll
     880 svchost.exe          0x71ad0000 True   True   True  \WINDOWS\system32\wsock32.dll
     880 svchost.exe          0x774e0000 True   True   True  \WINDOWS\system32\ole32.dll
     880 svchost.exe          0x77920000 True   True   True  \WINDOWS\system32\setupapi.dll
     880 svchost.exe          0x7e410000 True   True   True  \WINDOWS\system32\user32.dll
     880 svchost.exe          0x7c900000 True   True   True  \WINDOWS\system32\ntdll.dll
     880 svchost.exe          0x77f10000 True   True   True  \WINDOWS\system32\gdi32.dll
     880 svchost.exe          0x77120000 True   True   True  \WINDOWS\system32\oleaut32.dll
     880 svchost.exe          0x5cb70000 True   True   True  \WINDOWS\system32\shimeng.dll
     880 svchost.exe          0x74980000 True   True   True  \WINDOWS\system32\msxml3.dll
     880 svchost.exe          0x009a0000 False  False  False \WINDOWS\system32\msxml3r.dll
     880 svchost.exe          0x77e70000 True   True   True  \WINDOWS\system32\rpcrt4.dll
     880 svchost.exe          0x769c0000 True   True   True  \WINDOWS\system32\userenv.dll
     880 svchost.exe          0x7c800000 True   True   True  \WINDOWS\system32\kernel32.dll
     880 svchost.exe          0x76fd0000 True   True   True  \WINDOWS\system32\clbcatq.dll
     880 svchost.exe          0x76b20000 True   True   True  \WINDOWS\system32\atl.dll
     880 svchost.exe          0x71bf0000 True   True   True  \WINDOWS\system32\samlib.dll
     880 svchost.exe          0x77690000 True   True   True  \WINDOWS\system32\ntmarta.dll
     880 svchost.exe          0x77c10000 True   True   True  \WINDOWS\system32\msvcrt.dll
     880 svchost.exe          0x760f0000 True   True   True  \WINDOWS\system32\termsrv.dll
     880 svchost.exe          0x76fc0000 True   True   True  \WINDOWS\system32\rasadhlp.dll
     880 svchost.exe          0x76c30000 True   True   True  \WINDOWS\system32\wintrust.dll
```

P8: ¿Cuál es la dirección base de la DLL inyectada?

R: 0x980000

En algunos casos las DLL inyectadas no aparecen en dlllist porque no están registradas en las listas estándar del loader.. Se utilizó el plugin malfind para el PID 880 y se encontró la dirección base 0x980000.

```
78-20230213-171333.raw --profile=WinXPSP2x86 malfind -p 880
Volatility Foundation Volatility Framework 2.6
Process: svchost.exe Pid: 880 Address: 0x980000
Vad Tag: VadS Protection: PAGE_EXECUTE_READWRITE
Flags: CommitCharge: 9, MemCommit: 1, PrivateMemory: 1, Protection: 6

0x00980000  4d 5a 90 00 03 00 00 00 04 00 00 00 ff ff 00 00   MZ..............
0x00980010  b8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00   ........@.......
0x00980020  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00   ................
0x00980030  00 00 00 00 00 00 00 00 00 00 00 00 f8 00 00 00   ................

0x00980000 4d               DEC EBP
0x00980001 5a               POP EDX
0x00980002 90               NOP
0x00980003 0003             ADD [EBX], AL
0x00980005 0000             ADD [EAX], AL
0x00980007 000400           ADD [EAX+EAX], AL
0x0098000a 0000             ADD [EAX], AL
0x0098000c ff               DB 0xff
0x0098000d ff00             INC DWORD [EAX]
0x0098000f 00b800000000     ADD [EAX+0x0], BH
0x00980015 0000             ADD [EAX], AL
0x00980017 004000           ADD [EAX+0x0], AL
0x0098001a 0000             ADD [EAX], AL
0x0098001c 0000             ADD [EAX], AL
0x0098001e 0000             ADD [EAX], AL
0x00980020 0000             ADD [EAX], AL
0x00980022 0000             ADD [EAX], AL
```